Projekt - Etap 2

Podstawy Cyberbezpieczeństwa 25Z

kierunek - Telekomunikacja

Autorzy:

Jakub Surma 327768

Kajetan Wilkowski 331542

Albert Kołsut 331493

16 grudnia 2025

WYDZIAŁ ELEKTRONIKI
I TECHNIK INFORMACYJNYCH

Spis treści

1 Wprowadzenie **2**
1.1 Treść zadania 2
1.2 Opis środowiska 2

2 Przebieg analizy danych wejściowych **2**
2.1 Dane zainfekowanego komputera 2
2.1.1 Adres IP 2
2.1.2 Nazwa hosta i konta 3
2.2 Rozpoczęcie ataku 3
2.3 Analiza pliku .dat 4
2.4 Pobieranie plików png i jpeg 5
2.5 Nawiązywanie połączeń 5
2.6 Pakiety Hello Client 6
2.7 Porty pocztowe 6
2.8 Statystyki TCP 7

3 Podsumowanie **7**

1 Wprowadzenie

1.1 Treść zadania

Celem drugiej fazy naszego projektu było przeprowadzenie analizy powłamaniowej, po incydencie, do którego doszło na maszynie z systemem operacyjnym Windows. Materiał badawczy stanowi plik z zapisem ruchu sieciowego (plik - faza2_22Z_red.pcap) z zainfekowanego hosta. Zadanie polegało na analizie tego zapisu, wykryciu i odtworzeniu przebiegu ataku.

1.2 Opis środowiska

Analiza powłamaniowa przeprowadzona została na systemie operacyjnym Windows 11, czyli powszechnie używanej, najnowszej wersji systemu. Narzędzia, które okazały się do niej przydatne to:

- Wireshark 4.6.2. - najnowsza wersja darmowego programu, który wybraliśmy ze względu na wcześniejsze doświadczenie w pracy z nim. Narzędzie to pozwala przechwytywać, odkodowywać oraz filtrować wysyłane pakiety TCP/UDP, co było niezbędne do analizy.
- URLHaus – darmowy serwis i baza danych projektu abuse.ch, który wybraliśmy ze względu na jego wiarygodność w śledzeniu dystrybucji złośliwego oprogramowania. Narzędzie to pozwala wyszukiwać, weryfikować oraz identyfikować złośliwe adresy URL (malware), co było niezbędne do sprawdzenia źródeł zagrożeń.

2 Przebieg analizy danych wejściowych

Analizę powłamaniową rozpoczęliśmy od programu Wireshark, którym przebadaliśmy plik faza2_22Z_red.pcap.

2.1 Dane zainfekowanego komputera

Pierwsze informacje jakich szukaliśmy dotyczyły zainfekowanego komputera, aby lepiej orientować się w całości sytuacji. Adres IP, nazwa hosta oraz nazwa konta osoby atakowanej są najbardziej podstawowymi identyfikatorami, które mogliśmy otrzymać stosunkowo łatwo.

2.1.1 Adres IP

Za pomocą Wiresharka posortowaliśmy występujące adresy IP. Zauważyliśmy, że jeden znacznie wyróżniał się liczebnością na tle reszty i był to szukany adres zainfekowanego komputera - **172.17.4.206**.

Topic / Item	Cou	Average	Min Val	Max Val	Rate (ms)	Percent	Burst Rate	Burst Start
IPv4 Statistics/All Addresses	27223				0,0050	100%	3,7600	4636,980
172.17.4.206	27221				0,0050	99,99%	3,7600	4636,980
104.93.49.229	11685				0,0021	42,92%	3,7500	4636,980
45.32.211.207	3779				0,0007	13,88%	3,6000	4502,123
54.36.108.120	2291				0,0004	8,42%	0,5700	4741,294
172.17.4.4	2281				0,0004	8,38%	1,9500	1,495
185.183.99.115	1253				0,0002	4,60%	1,5700	46,432
23.47.169.154	765				0,0001	2,81%	1,1000	53,686
24.179.77.148	458				0,0001	1,68%	1,6400	447,366
54.225.155.255	394				0,0001	1,45%	0,4700	4741,280
8.249.131.254	332				0,0001	1,22%	1,7600	611,995
142.250.115.28	309				0,0001	1,14%	0,1300	4744,707
40.70.224.145	281				0,0001	1,03%	0,5800	606,900
23.38.181.191	220				0,0000	0,81%	0,5600	52,332
23.21.48.44	211				0,0000	0,78%	0,3600	4703,402
64.29.151.102	198				0,0000	0,73%	0,1400	4743,572
54.235.175.90	186				0,0000	0,68%	0,2300	4900,463
72.21.81.240	164				0,0000	0,60%	0,2600	606,600
50.19.216.111	163				0,0000	0,60%	0,2300	4668,935
172.17.4.1	150				0,0000	0,55%	0,0200	1,080
45.79.71.155	139				0,0000	0,51%	0,1000	4746,464
52.114.132.73	130				0,0000	0,48%	0,1300	610,055

Rysunek 1: Adres IP

2.1.2 Nazwa hosta i konta

Znając adres IP zainfekowanego komputera oraz wykorzystując filtrowanie za pomocą protokołu SMB2, które pozwoliło nam odsiać szum sieciowy, odnaleźliśmy pakiety zawierające nazwy hosta i konta, których szukaliśmy:

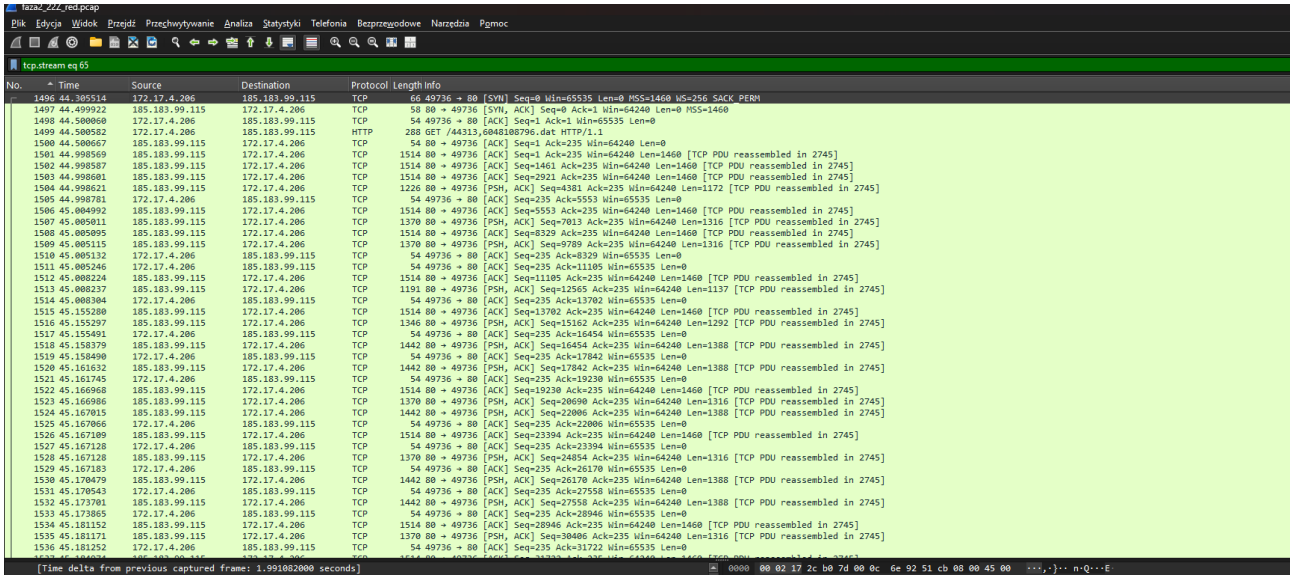
- Host - **DESKTOP-V0FEH1L**
- Konto - **alfonso.paternoster**
- Domena (dodatkowo) - NUTMEG-STATION

```
Session Id: 0x0000e0006c000075 Acct:alfonso.paternoster Domain:NUTMEG-STATION Host:DESKTOP-V0FEH1L
    [Account: alfonso.paternoster]
    [Domain: NUTMEG-STATION]
    [Host: DESKTOP-V0FEH1L]
    [Authenticated in Frame: 1036]
Signature: 00000000000000000000000000000000
[Response in: 1036]
[Time to response: 1.071000 milliseconds]
```

Rysunek 2: Nazwa hosta i konta

2.2 Rozpoczęcie ataku

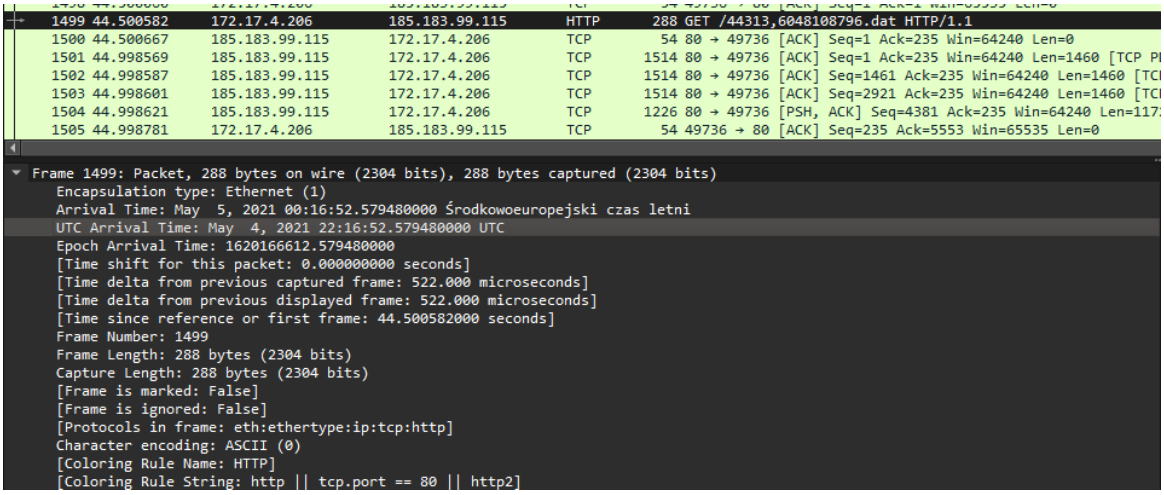
Aby odnaleźć moment rozpoczęcia ataku filtrowaliśmy pakiety związane z protokołem HTTP, trafiając w końcu na właściwy trop, za którym podążyliśmy śledząc strumień TCP 65.



Rysunek 3: Rozpoczęcie ataku

Jak widać na powyższym obrazie, pakiet numer 1499 pobiera podejrzany plik **44313,6048108796.dat** ze strony internetowej, co najprawdopodobniej zainicjował mail phishingowy. W następnych krokach będziemy badać jego zawartość oraz z czym się on wiąże, ale mając moment kiedy atak się zaczął, możemy odczytać jego dokładną datę oraz godzinę, czyli:

- **04.05.2021 | 22:16:52 UTC**



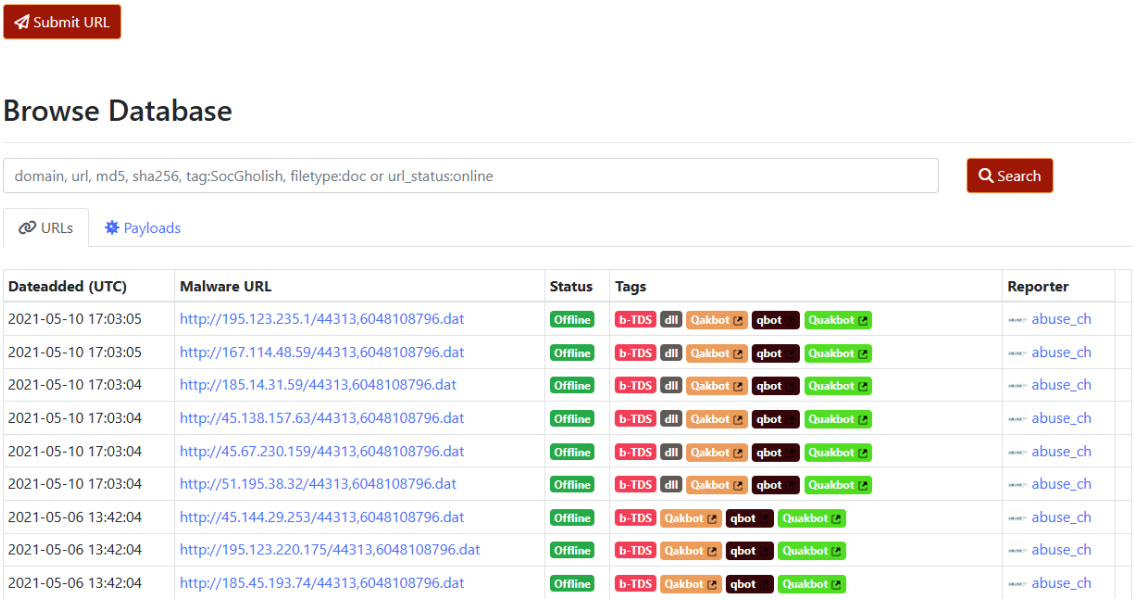
1499	44.500582	172.17.4.206	185.183.99.115	HTTP	288 GET /44313,6048108796.dat HTTP/1.1
1500	44.500667	185.183.99.115	172.17.4.206	TCP	54 80 → 49736 [ACK] Seq=1 Ack=235 Win=64240 Len=0
1501	44.998569	185.183.99.115	172.17.4.206	TCP	1514 80 → 49736 [ACK] Seq=1 Ack=235 Win=64240 Len=1460 [TCP P
1502	44.998587	185.183.99.115	172.17.4.206	TCP	1514 80 → 49736 [ACK] Seq=1461 Ack=235 Win=64240 Len=1460 [TC
1503	44.998601	185.183.99.115	172.17.4.206	TCP	1514 80 → 49736 [ACK] Seq=2921 Ack=235 Win=64240 Len=1460 [TC
1504	44.998621	185.183.99.115	172.17.4.206	TCP	1226 80 → 49736 [PSH, ACK] Seq=4381 Ack=235 Win=64240 Len=117
1505	44.998781	172.17.4.206	185.183.99.115	TCP	54 49736 → 80 [ACK] Seq=235 Ack=5553 Win=65535 Len=0

```
Frame 1499: Packet, 288 bytes on wire (2304 bits), 288 bytes captured (2304 bits)
    Encapsulation type: Ethernet (1)
    Arrival Time: May  5, 2021 00:16:52.579480000 Środkowoeuropejski czas letni
    UTC Arrival Time: May  4, 2021 22:16:52.579480000 UTC
    Epoch Arrival Time: 1620166612.579480000
    [Time shift for this packet: 0.000000000 seconds]
    [Time delta from previous captured frame: 522.000 microseconds]
    [Time delta from previous displayed frame: 522.000 microseconds]
    [Time since reference or first frame: 44.500582000 seconds]
    Frame Number: 1499
    Frame Length: 288 bytes (2304 bits)
    Capture Length: 288 bytes (2304 bits)
    [Frame is marked: False]
    [Frame is ignored: False]
    [Protocols in frame: eth:ethertype:ip:tcp:http]
    Character encoding: ASCII (0)
    [Coloring Rule Name: HTTP]
    [Coloring Rule String: http || tcp.port == 80 || http2]
```

Rysunek 4: Data i czas ataku

2.3 Analiza pliku .dat

Za pomocą strony URLHaus, przebadaliśmy plik w celu określenia czy posiada jakieś szkodliwe oprogramowanie i okazało się, że nasze podejrzenia były słuszne.



Submit URL

Browse Database

domain, url, md5, sha256, tag:SocGholish, filetype:doc or url_status:online

Search

URLs Payloads

Dateadded (UTC)	Malware URL	Status	Tags	Reporter
2021-05-10 17:03:05	http://195.123.235.1/44313,6048108796.dat	Offline	b-TDS dll Qakbot qbot Quakbot	abuse_ch
2021-05-10 17:03:05	http://167.114.48.59/44313,6048108796.dat	Offline	b-TDS dll Qakbot qbot Quakbot	abuse_ch
2021-05-10 17:03:04	http://185.14.31.59/44313,6048108796.dat	Offline	b-TDS dll Qakbot qbot Quakbot	abuse_ch
2021-05-10 17:03:04	http://45.138.157.63/44313,6048108796.dat	Offline	b-TDS dll Qakbot qbot Quakbot	abuse_ch
2021-05-10 17:03:04	http://45.67.230.159/44313,6048108796.dat	Offline	b-TDS dll Qakbot qbot Quakbot	abuse_ch
2021-05-10 17:03:04	http://51.195.38.32/44313,6048108796.dat	Offline	b-TDS dll Qakbot qbot Quakbot	abuse_ch
2021-05-06 13:42:04	http://45.144.29.253/44313,6048108796.dat	Offline	b-TDS Qakbot qbot Quakbot	abuse_ch
2021-05-06 13:42:04	http://195.123.220.175/44313,6048108796.dat	Offline	b-TDS Qakbot qbot Quakbot	abuse_ch
2021-05-06 13:42:04	http://185.45.193.74/44313,6048108796.dat	Offline	b-TDS Qakbot qbot Quakbot	abuse_ch

Rysunek 5: URLHaus

Wirus, z którym mamy doczynienia to Qakbot, czyli jeden z najstarszych trojanów bankowych, którego głównym zadaniem jest wpuszczanie do systemu innych wirusów. Jego typowe zachowanie zakłada między innymi:

1. Nawiązanie połączenia - Po infekcji Qakbot natychmiast łączy się z serwerem sterującym. Często pobiera wtedy dodatkowe komponenty lub aktualizacje pod postacią plików z mylącymi rozszerzeniami (np. .dat, .png lub .gif)
2. Kradzież danych - Przeszukuje zainfekowany komputer, aby wykraść hasła, dane logowania do bankowości, historię przeglądarki oraz e-maile (które potem wykorzystuje do dalszego phishingu).
3. Ruch boczny - Agresywnie próbuje rozprzestrzenić się na inne komputery w sieci lokalnej, często wykorzystując luki w protokole SMB lub skradzione dane administratora.
4. Instalacja kolejnych zagrożeń - W końcowej fazie ataku Qakbot często służy jako drzwi do zainstalowania oprogramowania typu ransomware (szyfrującego dyski), np. Black Basta czy Egregor.

2.4 Pobieranie plików png i jpeg

Po pobraniu pierwszego pliku .dat, użytkownik zaczął pobierać pliki typu .png i .jpeg (widoczne na zdjęciu), co w pełni pokrywa się z jego standardowym działaniem. Rozszerzenia te są tylko przykywką, gdyż tak naprawdę są to pliki binarne zawierające rozszerzoną wersję naszego wirusa bądź kompletnie inne typy złośliwego oprogramowania.

1499	44.500582	172.17.4.206	185.183.99.115	HTTP	288	GET /44313,6048108796.dat HTTP/1.1
2956	52.754258	172.17.4.206	23.47.169.154	HTTP	276	GET /image/global.51429.acentoprodimg.f914a031-2137-4541-bf4a-c51b859a25ff.450bed70-383f-4631-80e3-a121d2c399a6?w=601 HTTP/1.1
2958	52.754405	172.17.4.206	23.47.169.154	HTTP	277	GET /image/global.51429.acentoprodimg.f914a031-2137-4541-bf4a-c51b859a25ff.450bed70-383f-4631-80e3-a121d2c399a6?w=1281 HTTP/1.1
2968	52.761150	172.17.4.206	23.47.169.154	HTTP	456	GET /image/global.52176.acentoprodimg.d2241958-8d86-4a33-bd6d-24377b7fef15.ea4b7055-2810-4f06-98ce-3e3dea57b2e9?w=601 HTTP/1.1
2970	52.761199	172.17.4.206	23.47.169.154	HTTP	456	GET /image/global.19783.acentoprodimg.a7c4e200-23fb-4f82-a16c-d8dc59ef5d51.b2ca9cb6-9fc1-4d6b-90cb-7bab2c0fcdef?w=601 HTTP/1.1
3268	53.173645	172.17.4.206	23.47.169.154	HTTP	450	GET /image/global.20758.acentoprodimg.4fad244a-ed1e-414a-b2f3-e3720eeaca51.f3577151-5767-42b6-bb67-d3727006a72a HTTP/1.1
3318	53.235599	172.17.4.206	23.47.169.154	HTTP	464	GET /image/apps.45464.14137276003875252.d1d6dd04-81e9-424d-a1b6-7a81e52dfeef.656ba41f-9220-4ebf-9cf4-a685da2f558d?w=172&h=258 HTTP/1.1
3319	53.235638	172.17.4.206	23.47.169.154	HTTP	464	GET /image/apps.11693.14503766937567901.176691f4-19f9-48ef-a75c-2af62972b059.04097907-d16b-47f1-b1a6-83fbc59bb15c?w=172&h=258 HTTP/1.1
3322	53.235821	172.17.4.206	23.47.169.154	HTTP	464	GET /image/apps.13825.14369454977035291.312a1827-6832-45f4-885d-562c4148d669.5c931ffa-b74a-45a6-a9cb-082c7d9cddd9?w=172&h=258 HTTP/1.1
3447	53.408070	172.17.4.206	23.47.169.154	HTTP	462	GET /image/apps.996.13845902377942213.3e857550-75c9-40ef-b9f1-c710cf0a9b88.f4863eba-e3ba-4fa3-bd3c-26aa6fe46293?w=172&h=258 HTTP/1.1
3587	53.543554	172.17.4.206	23.47.169.154	HTTP	450	GET /image/global.40455.acentoprodimg.7f4d57e5-c726-4f64-a1a7-2358c9c2aca4.dc6cc2ed-6332-4997-a8cd-cb4761bd7ea2 HTTP/1.1
3659	53.622077	172.17.4.206	23.47.169.154	HTTP	464	GET /image/apps.15459.14018880429702282.f227304a-b5a1-43b5-a5ef-c3a2eafb2c2d.9871105b-6b54-4a8b-9295-e4197c93988e?w=172&h=258 HTTP/1.1
3660	53.622109	172.17.4.206	23.47.169.154	HTTP	464	GET /image/apps.57047.14380149729470603.1aef82b1-76c1-46e9-b3a7-bfea4ea54b01.ed79b095-68f1-4190-9ff1-74e2fbf0103a?w=172&h=258 HTTP/1.1
3662	53.622187	172.17.4.206	23.47.169.154	HTTP	464	GET /image/apps.15387.13812021519099434.2bf8d983-bebb-467e-9b6a-e52bb2610650.46530b30-f947-46d5-ae2e-dd024af3da59?w=172&h=258 HTTP/1.1
3754	53.733927	172.17.4.206	23.47.169.154	HTTP	464	GET /image/apps.15792.14098991041572765.f2e8d44f-55f2-4b91-b7c9-5fe108fe9c1a.f803e6b2-b8a5-47bb-98f1-9843909974ce?w=172&h=258 HTTP/1.1

Rysunek 6: Pobranie pliku z obrazem

2.5 Nawiązywanie połączeń

Zastosowanie filtra wykluczającego ruch HTTP/HTTPS z wykluczeniem portów 80 i 443 (celowy zabieg) pozwoliło wyodrębnić trzy krytyczne zachowania zainfekowanego hosta 172.17.4.206 w fazie nawiązywania połączeń:

- Propagacja lokalna - Próby infekcji sąsiednich stacji w sieci LAN poprzez wykorzystanie usług udostępniania plików (porty 445 i 135).
- Cykliczne, nieudane próby połączenia z serwerem sterującym atakującego (2.7.116.188) na porcie 2222.
- Spam - Masowe nawiązywanie sesji z publicznymi serwerami pocztowymi (porty 25, 465, 587, 993), wskazujące na kradzież korespondencji lub wykorzystanie maszyny do rozsyłania spamu.

tcp.flags eq 0x0002 and !(tcp.port eq 80) and !(tcp.port eq 443)

No.	Time	Source	Destination	Protocol	Length	Info
4471	435.569353	172.17.4.206	172.17.4.4	TCP	66	49770 → 135 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
4478	435.570824	172.17.4.206	172.17.4.4	TCP	66	49771 → 49667 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
5857	901.659996	172.17.4.206	172.17.4.4	TCP	66	49789 → 445 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
6025	1106.606588	172.17.4.206	172.17.4.4	TCP	66	49796 → 135 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
6032	1106.609565	172.17.4.206	172.17.4.4	TCP	66	49797 → 49667 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
6055	1106.616772	172.17.4.206	172.17.4.4	TCP	66	49798 → 389 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
6072	1106.621778	172.17.4.206	172.17.4.4	TCP	66	49799 → 389 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
6242	1801.664697	172.17.4.206	172.17.4.4	TCP	66	49803 → 445 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
6442	2701.678589	172.17.4.206	172.17.4.4	TCP	66	49807 → 445 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
6659	3601.693425	172.17.4.206	172.17.4.4	TCP	66	49812 → 445 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
6850	3966.569804	172.17.4.206	2.7.116.188	TCP	66	49821 → 2222 [SYN] Seq=0 Win=65535 Len=0 MSS=1460 WS=256 SACK_PERM
6851	3967.597013	172.17.4.206	2.7.116.188	TCP	66	[TCP Retransmission] 49821 → 2222 [SYN] Seq=0 Win=65535 Len=0 MSS=1460 WS=256 SA
6852	3969.628757	172.17.4.206	2.7.116.188	TCP	66	[TCP Retransmission] 49821 → 2222 [SYN] Seq=0 Win=65535 Len=0 MSS=1460 WS=256 SA
6853	3973.643862	172.17.4.206	2.7.116.188	TCP	66	49822 → 2222 [SYN] Seq=0 Win=65535 Len=0 MSS=1460 WS=256 SACK_PERM
6856	3974.643440	172.17.4.206	2.7.116.188	TCP	66	[TCP Retransmission] 49822 → 2222 [SYN] Seq=0 Win=65535 Len=0 MSS=1460 WS=256 SA
6857	3976.657163	172.17.4.206	2.7.116.188	TCP	66	[TCP Retransmission] 49822 → 2222 [SYN] Seq=0 Win=65535 Len=0 MSS=1460 WS=256 SA
6860	3982.675340	172.17.4.206	2.7.116.188	TCP	66	49823 → 2222 [SYN] Seq=0 Win=65535 Len=0 MSS=1460 WS=256 SACK_PERM
6861	3983.688480	172.17.4.206	2.7.116.188	TCP	66	[TCP Retransmission] 49823 → 2222 [SYN] Seq=0 Win=65535 Len=0 MSS=1460 WS=256 SA
6862	3985.690355	172.17.4.206	2.7.116.188	TCP	66	[TCP Retransmission] 49823 → 2222 [SYN] Seq=0 Win=65535 Len=0 MSS=1460 WS=256 SA
6864	3989.707733	172.17.4.206	2.7.116.188	TCP	66	49824 → 2222 [SYN] Seq=0 Win=65535 Len=0 MSS=1460 WS=256 SACK_PERM
6867	3990.720909	172.17.4.206	2.7.116.188	TCP	66	[TCP Retransmission] 49824 → 2222 [SYN] Seq=0 Win=65535 Len=0 MSS=1460 WS=256 SA
6868	3992.721160	172.17.4.206	2.7.116.188	TCP	66	[TCP Retransmission] 49824 → 2222 [SYN] Seq=0 Win=65535 Len=0 MSS=1460 WS=256 SA
9536	4501.710990	172.17.4.206	172.17.4.4	TCP	66	49835 → 445 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
22507	4640.794047	172.17.4.206	54.36.108.120	TCP	66	49843 → 65400 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
23006	4678.547101	172.17.4.206	142.250.115.28	TCP	66	49853 → 25 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
23018	4678.694422	172.17.4.206	142.250.115.28	TCP	66	49854 → 465 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
23027	4678.881975	172.17.4.206	98.137.157.46	TCP	66	49855 → 995 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
23069	4679.941246	172.17.4.206	45.79.71.155	TCP	66	49856 → 2525 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
23075	4680.044979	172.17.4.206	142.250.115.28	TCP	66	49857 → 587 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
23089	4680.194796	172.17.4.206	142.250.115.28	TCP	66	49858 → 25 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
23134	4681.295866	172.17.4.206	64.29.151.102	TCP	66	49859 → 110 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
23145	4681.449106	172.17.4.206	142.250.113.109	TCP	66	49860 → 993 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
23154	4681.556021	172.17.4.206	45.79.71.155	TCP	66	49861 → 2525 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
23220	4702.740926	172.17.4.206	59.158.21.171	TCP	66	49863 → 25 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
23622	4705.263331	172.17.4.206	64.29.151.102	TCP	66	49873 → 143 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
23623	4705.263763	172.17.4.206	45.79.71.155	TCP	66	49874 → 2525 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
23647	4705.507374	172.17.4.206	98.137.157.46	TCP	66	49875 → 995 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
23653	4705.620635	172.17.4.206	64.29.151.102	TCP	66	49876 → 143 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
23654	4705.621072	172.17.4.206	45.79.71.155	TCP	66	49877 → 2525 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
23655	4705.621509	172.17.4.206	98.137.157.46	TCP	66	49878 → 995 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
23656	4705.621914	172.17.4.206	142.250.115.28	TCP	66	49879 → 465 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
23657	4705.622313	172.17.4.206	142.250.115.28	TCP	66	49880 → 25 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
23719	4706.098218	172.17.4.206	142.250.115.28	TCP	66	49881 → 25 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
23756	4706.708467	172.17.4.206	142.250.115.28	TCP	66	49882 → 465 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
23757	4706.708901	172.17.4.206	64.29.151.102	TCP	66	49883 → 110 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
23770	4706.867256	172.17.4.206	142.250.115.28	TCP	66	49884 → 25 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
23781	4707.026468	172.17.4.206	64.29.151.102	TCP	66	49885 → 110 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
23782	4707.026808	172.17.4.206	142.250.115.28	TCP	66	49886 → 25 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
23783	4707.027256	172.17.4.206	45.79.71.155	TCP	66	49887 → 2525 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
23784	4707.027653	172.17.4.206	142.250.115.28	TCP	66	49888 → 587 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM

Rysunek 7: Ruch z zainfekowanego komputera w sieci lokalnej

2.6 Pakiety Hello Client

Analiza pakietów Client Hello w fazie nawiązywania połączeń szyfrowanych (SSL/TLS) ujawniła istotną anomalię, która wystąpiła po infekcji hosta. Oprócz standardowego ruchu tła, zaobserwowano serię połączeń do podejrzanych adresów IP (np. 45.32.211.207, 24.179.77.148), w których brakowało rozszerzenia SNI. SNI jest wręcz obowiązkowym standardem, a jego brak oraz bezpośrednie łączenie się z adresami IP sugeruje, że komunikację inicjuje zautomatyzowany skrypt złośliwego oprogramowania, a nie użytkownik przeglądarki.

(http.request or ssl.handshake.type == 1) and!(ssdp)

No.	Time	Source	Destination	Protocol	Length	Info
5903	925.266418	172.17.4.206	13.107.42.23	TLSv1.2	242	Client Hello (SNI=config.edge.skype.com)
5907	925.271475	172.17.4.206	13.107.42.23	TLSv1.2	242	Client Hello (SNI=config.edge.skype.com)
6000	1066.263187	172.17.4.206	24.179.77.148	TLSv1.2	203	Client Hello
6136	1383.246693	172.17.4.206	24.179.77.148	TLSv1.2	203	Client Hello
6173	1512.452759	172.17.4.206	52.114.128.43	TLSv1.2	268	Client Hello (SNI=v10.events.data.microsoft.com)
6222	1700.064588	172.17.4.206	24.179.77.148	TLSv1.2	203	Client Hello
6307	2016.743968	172.17.4.206	24.179.77.148	TLSv1.2	203	Client Hello
6361	2337.667604	172.17.4.206	24.179.77.148	TLSv1.2	203	Client Hello
6428	2658.496418	172.17.4.206	24.179.77.148	TLSv1.2	203	Client Hello
6468	2703.827067	172.17.4.206	52.114.132.73	TLSv1.2	268	Client Hello (SNI=v10.events.data.microsoft.com)
6510	2783.403305	172.17.4.206	142.250.138.94	TLSv1.2	260	Client Hello (SNI=update.googleapis.com)
6552	2975.307350	172.17.4.206	24.179.77.148	TLSv1.2	203	Client Hello
6619	3292.129517	172.17.4.206	24.179.77.148	TLSv1.2	203	Client Hello
6696	3609.010298	172.17.4.206	24.179.77.148	TLSv1.2	203	Client Hello
6759	3902.505619	172.17.4.206	52.185.211.133	TLSv1.2	270	Client Hello (SNI=settings-win.data.microsoft.com)
6789	3925.956395	172.17.4.206	24.179.77.148	TLSv1.2	203	Client Hello
6837	3962.734701	172.17.4.206	72.21.81.240	HTTP	341	GET /msdownload/update/v3/static/trustedr/en/disallowedcer
6840	3962.793381	172.17.4.206	72.21.81.240	HTTP	334	GET /msdownload/update/v3/static/trustedr/en/authrootstl.c
6875	4001.788044	172.17.4.206	45.32.211.207	TLSv1.2	203	Client Hello
6931	4242.682598	172.17.4.206	45.32.211.207	TLSv1.2	203	Client Hello
7966	4246.072279	172.17.4.206	45.32.211.207	TLSv1.2	203	Client Hello
7997	4306.856841	172.17.4.206	45.32.211.207	TLSv1.2	203	Client Hello
8481	4309.207078	172.17.4.206	45.32.211.207	TLSv1.2	203	Client Hello
8513	4371.070503	172.17.4.206	45.32.211.207	TLSv1.2	203	Client Hello
9273	4373.888508	172.17.4.206	45.32.211.207	TLSv1.2	203	Client Hello
9372	4435.344523	172.17.4.206	45.32.211.207	TLSv1.2	203	Client Hello
9427	4441.083235	172.17.4.206	45.32.211.207	TLSv1.2	203	Client Hello
9526	4499.509080	172.17.4.206	45.32.211.207	TLSv1.2	203	Client Hello
10480	4502.449624	172.17.4.206	45.32.211.207	TLSv1.2	203	Client Hello

Rysunek 8: Pakiety Hello Client

2.7 Porty pocztowe

Analiza ruchu na portach pocztowych wykazała, że zainfekowany komputer inicjuje masowe połączenia z zewnętrznymi serwerami pocztowymi. Widoczne na zrzucie odpowiedzi serwerów (banery powitalne typu 220 Service ready oraz +OK POP3 server ready) świadczą o tym, że malware próbuje nawiązać sesje w celu:

1. Rozsyłania spamu - Wykorzystując cudze serwery SMTP jako przekaźniki (co potwierdza komunikat błędu w pakiecie 26377 o braku autoryzacji dla ruchu 'unsolicited').
2. Kradzieży danych - Próby logowania się na skrzynki pocztowe przy użyciu skradzionych lub generowanych haseł, w celu przejęcia korespondencji ofiar.

smtp or imap or pop

No.	Time	Source	Destination	Protocol	Length	Info
23013	4678.641242	142.250.115.28	172.17.4.206	SMTP	112	S: 220 smtp-relay.gmail.com ESMTP z7sm1450566ooh.25 - gsmtp
23080	4680.119306	142.250.115.28	172.17.4.206	SMTP	112	S: 220 smtp-relay.gmail.com ESMTP k2sm1641411oou.13 - gsmtp
23104	4680.459957	142.250.115.28	172.17.4.206	SMTP	112	S: 220 smtp-relay.gmail.com ESMTP d12sm4931701qkj.5 - gsmtp
23142	4681.416017	64.29.151.102	172.17.4.206	POP	133	S: +OK POP3 Bigfoot v1.0 server ready <353.1620171240@mail31c26.carrierzone.com>
23634	4705.369882	64.29.151.102	172.17.4.206	IMAP	160	Response: * OK [CAPABILITY IMAP4REV1 LITERAL+ UTF8=ALL STARTTLS SASL-IR AUTH=LOGIN ID] mail70c26 IMAP4rev1 Bigfoot
23680	4705.714878	142.250.115.28	172.17.4.206	SMTP	112	S: 220 smtp-relay.gmail.com ESMTP x4sm1614024ooi.21 - gsmtp
23683	4705.730623	64.29.151.102	172.17.4.206	IMAP	160	Response: * OK [CAPABILITY IMAP4REV1 LITERAL+ UTF8=ALL STARTTLS SASL-IR AUTH=LOGIN ID] mail72c26 IMAP4rev1 Bigfoot
23741	4706.369946	142.250.115.28	172.17.4.206	SMTP	113	S: 220 smtp-relay.gmail.com ESMTP x188sm5445923vkb.3 - gsmtp
23766	4706.833790	64.29.151.102	172.17.4.206	POP	135	S: +OK POP3 Bigfoot v1.0 server ready <15236.1620171275@mail12c26.carrierzone.com>
23796	4707.073649	142.250.115.28	172.17.4.206	SMTP	113	S: 220 smtp-relay.gmail.com ESMTP q13sm1720091pjj.16 - gsmtp
23844	4707.141704	64.29.151.102	172.17.4.206	POP	134	S: +OK POP3 Bigfoot v1.0 server ready <1208.1620171275@mail31c26.carrierzone.com>
23847	4707.145717	142.250.115.28	172.17.4.206	SMTP	113	S: 220 smtp-relay.gmail.com ESMTP bv21sm1766391pjb.4 - gsmtp
23907	4707.244695	142.250.115.28	172.17.4.206	SMTP	111	S: 220 smtp-relay.gmail.com ESMTP x2sm3678742vsr.0 - gsmtp
24612	4743.221077	64.29.151.102	172.17.4.206	POP	135	S: +OK POP3 Bigfoot v1.0 server ready <25657.1620171311@mail74c26.carrierzone.com>
24615	4743.224139	64.29.151.102	172.17.4.206	POP	135	S: +OK POP3 Bigfoot v1.0 server ready <25653.1620171311@mail74c26.carrierzone.com>
24618	4743.228744	64.29.151.102	172.17.4.206	POP	134	S: +OK POP3 Bigfoot v1.0 server ready <2837.1620171311@mail31c26.carrierzone.com>
24655	4743.371119	142.250.115.28	172.17.4.206	SMTP	112	S: 220 smtp-relay.gmail.com ESMTP v12sm3669336pjn.0 - gsmtp
24658	4743.405506	142.250.115.28	172.17.4.206	SMTP	112	S: 220 smtp-relay.gmail.com ESMTP p15sm5274136pjg.3 - gsmtp
24661	4743.408606	64.29.151.102	172.17.4.206	POP	135	S: +OK POP3 Bigfoot v1.0 server ready <16410.1620171311@mail12c26.carrierzone.com>
24662	4743.408634	64.29.151.102	172.17.4.206	POP	135	S: +OK POP3 Bigfoot v1.0 server ready <25660.1620171311@mail74c26.carrierzone.com>
24678	4743.571618	64.29.151.102	172.17.4.206	IMAP	160	Response: * OK [CAPABILITY IMAP4REV1 LITERAL+ UTF8=ALL STARTTLS SASL-IR AUTH=LOGIN ID] mail29c26 IMAP4rev1 Bigfoot
24782	4744.669644	64.29.151.102	172.17.4.206	IMAP	160	Response: * OK [CAPABILITY IMAP4REV1 LITERAL+ UTF8=ALL STARTTLS SASL-IR AUTH=LOGIN ID] mail71c26 IMAP4rev1 Bigfoot
24785	4744.672697	64.29.151.102	172.17.4.206	IMAP	160	Response: * OK [CAPABILITY IMAP4REV1 LITERAL+ UTF8=ALL STARTTLS SASL-IR AUTH=LOGIN ID] mail29c26 IMAP4rev1 Bigfoot
24788	4744.675779	64.29.151.102	172.17.4.206	IMAP	160	Response: * OK [CAPABILITY IMAP4REV1 LITERAL+ UTF8=ALL STARTTLS SASL-IR AUTH=LOGIN ID] mail27c26 IMAP4rev1 Bigfoot
24814	4744.750679	142.250.115.28	172.17.4.206	SMTP	112	S: 220 smtp-relay.gmail.com ESMTP b63sm5658047qke.4 - gsmtp
24829	4744.781471	142.250.115.28	172.17.4.206	SMTP	113	S: 220 smtp-relay.gmail.com ESMTP c72sm1648393oob.11 - gsmtp
24833	4744.791448	142.250.115.28	172.17.4.206	SMTP	112	S: 220 smtp-relay.gmail.com ESMTP b1sm1441524oog.20 - gsmtp
24841	4744.829558	64.29.151.102	172.17.4.206	IMAP	160	Response: * OK [CAPABILITY IMAP4REV1 LITERAL+ UTF8=ALL STARTTLS SASL-IR AUTH=LOGIN ID] mail29c26 IMAP4rev1 Bigfoot
24844	4744.833459	64.29.151.102	172.17.4.206	IMAP	160	Response: * OK [CAPABILITY IMAP4REV1 LITERAL+ UTF8=ALL STARTTLS SASL-IR AUTH=LOGIN ID] mail27c26 IMAP4rev1 Bigfoot
24863	4744.970423	142.250.115.28	172.17.4.206	SMTP	114	S: 220 smtp-relay.gmail.com ESMTP mp16sm5854377pjb.15 - gsmtp
24922	4745.309946	64.29.151.102	172.17.4.206	IMAP	160	Response: * OK [CAPABILITY IMAP4REV1 LITERAL+ UTF8=ALL STARTTLS SASL-IR AUTH=LOGIN ID] mail71c26 IMAP4rev1 Bigfoot
24970	4745.921482	64.29.151.102	172.17.4.206	POP	134	S: +OK POP3 Bigfoot v1.0 server ready <8963.1620171314@mail19c26.carrierzone.com>
25005	4746.128530	64.29.151.102	172.17.4.206	POP	134	S: +OK POP3 Bigfoot v1.0 server ready <2907.1620171314@mail31c26.carrierzone.com>
25342	4765.986600	142.250.115.28	172.17.4.206	SMTP	111	S: 220 smtp-relay.gmail.com ESMTP z9sm4808949vsj.5 - gsmtp
25352	4766.114503	142.250.115.28	172.17.4.206	SMTP	112	S: 220 smtp-relay.gmail.com ESMTP k2sm1642811oou.13 - gsmtp
25384	4766.743410	142.250.115.28	172.17.4.206	SMTP	113	S: 220 smtp-relay.gmail.com ESMTP y13sm1511725ooq.23 - gsmtp
25391	4766.842350	142.250.115.28	172.17.4.206	SMTP	113	S: 220 smtp-relay.gmail.com ESMTP l127sm5353674vkg.0 - gsmtp
25839	4902.495717	64.29.151.102	172.17.4.206	IMAP	160	Response: * OK [CAPABILITY IMAP4REV1 LITERAL+ UTF8=ALL STARTTLS SASL-IR AUTH=LOGIN ID] mail73c26 IMAP4rev1 Bigfoot
25916	4904.058453	142.250.115.28	172.17.4.206	SMTP	111	S: 220 smtp-relay.gmail.com ESMTP w7sm4457944vsk.3 - gsmtp
25944	4904.422799	64.29.151.102	172.17.4.206	POP	135	S: +OK POP3 Bigfoot v1.0 server ready <21312.1620171472@mail18c26.carrierzone.com>
25973	4905.145639	142.250.115.28	172.17.4.206	SMTP	113	S: 220 smtp-relay.gmail.com ESMTP l127sm5355162vkg.0 - gsmtp
26221	4931.707673	142.250.115.28	172.17.4.206	SMTP	112	S: 220 smtp-relay.gmail.com ESMTP 200sm4872364vkx.6 - gsmtp
26233	4931.876611	142.250.115.28	172.17.4.206	SMTP	112	S: 220 smtp-relay.gmail.com ESMTP y15sm1757487ooh.5 - gsmtp
26268	4932.672354	64.29.151.102	172.17.4.206	POP	135	S: +OK POP3 Bigfoot v1.0 server ready <14985.1620171500@mail19c26.carrierzone.com>
26377	4955.250698	217.79.240.134	172.17.4.206	SMTP	270	S: 220-taurus.zoom.ph ESMTP Exim 4.94.2 #2 Wed, 05 May 2021 07:38:43 +0800 | We do not authorize the use of this system to transport unsolicited, |
26611	5096.096933	23.229.231.163	172.17.4.206	SMTP	251	S: 220-p3plcpnl0620.prod.phx3.secureserver.net ESMTP Exim 4.93 #2 Tue, 04 May 2021 16:41:04 -0700 | We do not authorize the use of this system to tr
26677	5146.662639	52.96.122.98	172.17.4.206	SMTP	164	S: 220 SA0PR12CA0003.outlook.office365.com Microsoft ESMTP MAIL Service ready at Tue, 4 May 2021 23:41:54 +0000

Rysunek 9: Porty pocztowe

2.8 Statystyki TCP

Analiza statystyk konwersacji TCP ujawniła zróżnicowany charakter ruchu sieciowego, wykraczający poza proste nawiązywanie połączeń i świadczący o całej strukturze ataku:

1. Pobieranie Payloadu - Zidentyfikowano transfer o wielkości 10 MB z adresu 104.93.49.229, co wskazuje na dociągnięcie dodatkowych modułów złośliwego oprogramowania.
2. Wyprowadzanie danych - Połączenie z adresem 54.36.108.120 na niestandardowym porcie 65400 trwało ponad 12 minut i zdecydowanie przeważało ilością danych wysłanych, co sugeruje aktywny kanał sterujący lub wykradanie danych.
3. Rozprzestrzenianie - Długotrwała (3 min) sesja SMB z lokalnym hostem 172.17.4.4 potwierdza próby penetracji sieci wewnętrznej.

Ethernet · 7 | IPv4 · 64 | IPv6 | TCP · 340 | UDP · 241

Adres A	Port A	Adres B	Port B	Pakiety	Bajty	Identyfikator strumienia	Packets A → B	Bytes A → B	Packets B → A	Bytes B → A	Rel Start	Czas trwania	Bits/s A → B	Bits/s B → A	Flows
172.17.4.206	49842	104.93.49.229	443	11 685	10 MB	169	4595	249 kB	7090	10 MB	4629.034710	109.8797	18 kbps	743 kbps	4
172.17.4.206	49843	54.36.108.120	65400	2291	483 kB	170	1037	369 kB	1254	114 kB	4640.794047	723.2548	4086 bits/s	1261 bits/s	718
172.17.4.206	49736	185.183.99.115	80	1253	1 MB	65	546	30 kB	707	1 MB	44.305514	18.5910	12 kbps	435 kbps	2
172.17.4.206	49826	45.32.211.207	443	1031	915 kB	153	401	23 kB	630	892 kB	4242.631412	3.3392	54 kbps	2138 kbps	6
172.17.4.206	49834	45.32.211.207	443	930	880 kB	161	321	18 kB	609	862 kB	4499.332861	3.0080	48 kbps	2292 kbps	6
172.17.4.206	49830	45.32.211.207	443	756	745 kB	157	240	14 kB	516	731 kB	4371.017317	2.7688	40 kbps	2113 kbps	6
172.17.4.206	49684	172.17.4.4	445	320	82 kB	14	162	39 kB	158	43 kB	1.546892	183.6108	1691 bits/s	1860 bits/s	282
172.17.4.206	49828	45.32.211.207	443	480	457 kB	155	161	10 kB	319	447 kB	4306.801224	2.3197	33 kbps	1542 kbps	6
172.17.4.206	49774	40.70.224.145	443	281	209 kB	101	111	57 kB	170	152 kB	604.994209	3.3422	137 kbps	363 kbps	22

Rysunek 10: Statystki TCP

3 Podsumowanie

Przeprowadzona przez nas analiza ruchu sieciowego jednoznacznie potwierdza infekcję komputera o adresie 172.17.4.206 złośliwym oprogramowaniem typu Qakbot. Atak rozpoczął się od pobrania złośliwego pliku .dat z serwera zewnętrznego, co doprowadziło do nawiązania stałego kanału komunikacji z infrastrukturą przestępczą (C2) oraz wykradania danych. W kolejnych fazach ataku zainfekowana maszyna podjęła agresywne próby propagacji wewnątrz sieci lokalnej poprzez protokół SMB, a następnie uruchomiła moduł spamerski, generując masowy, nieautoryzowany ruch do zewnętrznych serwerów pocztowych.